

网上书店管理系统

技术报告

文档类型	技术报告
项目名称	网上书店管理系统
学生姓名	Bagtyyar Kovusov
学号	312024805043
技术栈	Servlet + JSP + JavaBean + JDBC + MySQL
安全设计	SM3 密码摘要、SM4 敏感字段加密、RBAC、审计日志
完成日期	2026 年 6 月 30 日

目录

第一章 系统概述

第二章 需求分析

第三章 总体架构设计

第四章 数据库设计

第五章 安全与国密设计

第六章 功能模块详细设计

第七章 关键代码与实现说明

第八章 测试与验证

第九章 部署与交付

附录：路由、表结构、答辩要点

第一章 系统概述

本系统围绕网上书店课程设计题目实现用户购书端和管理端两类业务场景，目标是在有限时间内完整展示 Servlet、JSP、JavaBean、JDBC、自定义 JSP 标签、MVC 与 DAO 等课程要求技术。

系统采用 Maven WAR 工程组织，提供嵌入式 Tomcat 启动类用于本地演示，同时仍可打包为标准 WAR 文件部署到 Tomcat 10。数据库采用 MySQL，页面采用 JSP 与 JSTL。

安全方面按照题目要求实现身份鉴别、访问控制、数据保密性与审计留痕。密码通过 salted SM3 摘要保存，手机号和地址按 SM4 加密存储，页面通过自定义标签完成脱敏。

用户端覆盖登录注册、图书浏览、购物车、结算、订单查看与确认收货。

管理端覆盖图书、分类、订单、用户、审计日志和销售统计。

系统保留简单清晰的分层结构，便于课程答辩时逐层解释。

第二章 需求分析

课程题目要求在教材网上书店基础上扩展普通购书者功能和管理端功能，并补充等保三级与国密算法相关控制。本项目把需求拆分为可演示的核心闭环，优先保证每一项评分技术都有真实运行路径。

用户侧需求包括账号登录、图书列表、购买入口、购物车数量调整、订单生成、订单状态跟踪和确认收货。管理侧需求包括管理员登录、图书上下架、订单发货、用户启停、分类维护、审计查询和统计图表。

由于课程项目时间有限，评价、退款、复杂多地址和轮播推荐等功能被作为可扩展项处理，不作为本次核心交付的阻塞条件。

必须满足：MVC + DAO、Servlet、JSP、JavaBean、JDBC、自定义标签。

必须满足：SM3、SM4、30 分钟会话超时、5 次失败锁定、RBAC。

必须满足：电子材料、SQL 脚本、数据库备份和系统使用说明。

第三章 总体架构设计

系统采用前端控制器模式，所有请求进入 DispatcherServlet，再由命令对象处理具体业务。过滤器在 Servlet 前执行认证、授权和审计逻辑，命令对象只负责一次业务动作。

业务层通过 Service 封装用例规则，DAO 层通过 JDBC 访问 MySQL。JSP 只负责展示，不直接拼接 SQL 或实现业务判断。该结构能清楚体现 MVC 与 DAO 的职责分离。

嵌入式 Tomcat 的 Launcher 类只用于演示和本地启动，真实部署时仍可使用 target/bookstore.war。

Browser -> Filter -> DispatcherServlet -> Command -> Service -> DAO -> MySQL。

模型对象均为 JavaBean，方便 JSP EL 和 JSTL 使用。

安全与密码工具集中在 security 包，降低误用概率。

第四章 数据库设计

数据库名称为 bookstore，使用 utf8mb4 字符集。核心表包括 user、category、book、cart_item、orders、order_item 和 audit_log。表结构保持简单，便于课程演示和答辩说明。

表名	用途	关键字段
user	保存登录账号、角色、安全状态和加密后的敏感字段	username、password_sm3、salt、phone_email
book	保存图书基础资料、库存和上下架状态	title、author、isbn、price、stock、category
cart_item	保存用户购物车明细	user_id、book_id、qty
orders	保存订单主表和状态流转信息	order_no、user_id、total、status、tracking
order_item	保存订单明细快照	order_id、title_snapshot、price_snapshot、
audit_log	保存关键操作日志	username、action、detail、ip、created_at

订单明细使用标题与价格快照，避免后续图书价格调整影响历史订单。购物车使用 user_id 与 book_id 唯一约束，保证同一本书在一个用户购物车中只有一行。

第五章 安全与国密设计（一）：身份鉴别

用户密码不以明文保存。注册和重置密码时生成随机 salt，并保存 SM3(salt + password) 的十六进制结果。登录时使用同一规则重新计算并比对。

PasswordPolicy 要求口令包含大小写字母、数字和特殊字符，长度不低于 8 位。LoginGuard 记录失败次数，达到 5 次后设置 lock_until，30 分钟内拒绝再次登录。

AuthFilter 维护 lastAccessedAt，会话空闲超过 30 分钟后清除登录态并要求重新登录。

单元测试覆盖 SM3 确定性、SM4 往返、密码复杂度和登录锁定规则。

种子数据只用于本地演示，报告正文不重复列出演示口令。

第五章 安全与国密设计（二）：访问控制

系统定义 CUSTOMER、OPERATOR_ADMIN、SYSTEM_ADMIN 和 AUDIT_ADMIN 四类角色。RbacFilter 对 /app/admin/* 统一拦截，保证角色判断不分散在 JSP 中。

运营管理员和系统管理员可进入业务管理模块；审计管理员只允许访问审计日志；普通客户不能进入管理端。RBAC 失败时返回 403。

系统管理员可管理非系统管理员账号，运营管理员只能管理普通客户，避免普通运营人员越权修改管理账号。

访问控制策略由 RbacPolicy 单独封装，便于单元测试。

最终烟测包含审计管理员访问销售统计时被 403 拒绝的截图。

第五章 安全与国密设计（三）：保密性与脱敏

手机号和地址等敏感字段通过 SM4 加密后保存，读取展示时只在授权场景中解密。页面层不直接实现掩码规则，而是通过自定义 JSP 标签 <shop:mask> 输出脱敏值。

MaskTag 调用 MaskUtil，根据 phone、name、idcard 等类型选择不同掩码规则。用户管理截图展示了姓名字段的脱敏输出，证明自定义标签实际参与页面渲染。

该设计把加密、解密和脱敏三类关注点拆开，避免 JSP 中出现重复的字符串处理逻辑。

密码只保存摘要，不可逆。

手机号和地址使用对称加密，便于业务系统需要时读取。

页面展示默认脱敏，降低截图和演示泄露风险。

第五章 安全与国密设计（四）：安全审计

系统对登录成功、登录失败、退出、购物结算、订单确认、管理员查看和管理端变更等动作写入 `audit_log`。审计管理员可通过专门页面查询最近日志。

审计日志包含动作、用户、时间、IP 和详情字段。详情字段只记录必要业务标识，例如订单 ID 或路径，不记录密码等敏感文本。

审计功能通过 `AuditService` 和 `AuditFilter/CommandSupport` 组合实现：过滤器记录管理端访问，命令记录关键业务变更。

最终烟测生成了登录、发货、确认收货、分类维护、用户状态变更和审计查看等日志。

审计管理员的权限被限制为审计查询，不能进入业务统计页。

第六章 功能模块详细设计 (1) : 用户登录与注册模块

LoginSubmitCommand 调用 UserService 校验用户名和口令, 成功后写入 SessionUser。RegisterSubmitCommand 调用密码策略和 UserRepository 创建普通客户。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转, Service 负责业务规则, DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL, 便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入: 来自表单、查询参数或当前会话。

处理: Service 校验业务规则并调用 DAO。

输出: 重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (2) : 图书浏览模块

BookListCommand 通过 BookService 查询在售图书, JSP 使用 JSTL 输出表格并隐藏下架图书。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转, Service 负责业务规则, DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL, 便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入: 来自表单、查询参数或当前会话。

处理: Service 校验业务规则并调用 DAO。

输出: 重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (3) : 购物车模块

CartService 负责新增、更新和移除购物车项，DAO 使用唯一约束保证同一用户同一本书不会重复插入多行。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转，Service 负责业务规则，DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL，便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入：来自表单、查询参数或当前会话。

处理：Service 校验业务规则并调用 DAO。

输出：重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (4) : 结算与订单模块

CheckoutCommand 从购物车生成订单和订单明细，扣减库存并把订单置为已支付待发货。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转，Service 负责业务规则，DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL，便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入：来自表单、查询参数或当前会话。

处理：Service 校验业务规则并调用 DAO。

输出：重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (5) : 客户订单模块

OrderListCommand 与 OrderDetailCommand
只查询当前用户自己的订单，防止通过参数查看他人订单。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转，Service 负责业务规则，DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL，便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入：来自表单、查询参数或当前会话。

处理：Service 校验业务规则并调用 DAO。

输出：重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (6) : 管理员仪表盘

管理后台根据当前角色显示业务入口或审计入口，普通客户无法访问。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转，Service 负责业务规则，DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL，便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入：来自表单、查询参数或当前会话。

处理：Service 校验业务规则并调用 DAO。

输出：重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (7) : 图书管理模块

管理员可以新增、编辑、上下架图书，用户端只展示 ON 状态图书。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转，Service 负责业务规则，DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL，便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入：来自表单、查询参数或当前会话。

处理：Service 校验业务规则并调用 DAO。

输出：重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (8) : 分类管理模块

分类目前采用扁平结构, parent_id 字段预留树形分类扩展。删除分类前检查是否仍有关联图书。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转, Service 负责业务规则, DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL, 便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入: 来自表单、查询参数或当前会话。

处理: Service 校验业务规则并调用 DAO。

输出: 重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (9) : 订单管理模块

管理员可以查看订单明细并对待发货订单填写物流单号后标记为已发货。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转，Service 负责业务规则，DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL，便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入：来自表单、查询参数或当前会话。

处理：Service 校验业务规则并调用 DAO。

输出：重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (10) : 用户管理模块

运营管理员可启停普通客户，系统管理员可管理非系统管理员账号，页面通过 mask 标签显示姓名。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转，Service 负责业务规则，DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL，便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入：来自表单、查询参数或当前会话。

处理：Service 校验业务规则并调用 DAO。

输出：重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (11) : 审计日志模块

审计管理员可按用户、动作、日期和关键字查询审计日志。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转，Service 负责业务规则，DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL，便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入：来自表单、查询参数或当前会话。

处理：Service 校验业务规则并调用 DAO。

输出：重定向或 forward 到 JSP 展示结果。

第六章 功能模块详细设计 (12) : 销售统计模块

StatsDao 按日期聚合已支付、已发货和已完成订单，StatsService 生成 JSP 直接可用的 ECharts 数据。

该模块遵循 Command -> Service -> DAO 的调用路径。Command 只处理参数、会话和跳转，Service 负责业务规则，DAO 负责 SQL 和结果集映射。

页面层保持朴素 JSP + JSTL，便于课程答辩时从请求 URL 追踪到 Servlet、JavaBean、DAO 和数据库表。

输入：来自表单、查询参数或当前会话。

处理：Service 校验业务规则并调用 DAO。

输出：重定向或 forward 到 JSP 展示结果。

第七章 关键代码与实现说明 (1) : DispatcherServlet 路由表

DispatcherServlet 在 init 中注册 GET/POST 路由，避免在 web.xml 中维护大量 Servlet 映射。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明（2）：CommandSupport 公共能力

CommandSupport 统一提供参数解析、当前用户读取、重定向消息和审计辅助方法。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明 (3) : JDBC 连接工具

Db 从 db.properties 读取 URL、用户名、口令和 SM4 密钥，DAO 通过 DriverManager 获取连接。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明（4）：事务边界

结算涉及订单、订单明细、库存和购物车清空，OrderDao 在一个连接中完成关键写入。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明 (5) : JavaBean 模型

User、Book、Order、OrderItem 等模型提供无参构造、getter 和 setter，满足 JSP EL 使用习惯。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明（6）：JSTL 页面

JSP 使用 `c:forEach`、`c:if`、`c:choose` 等标签控制展示，避免脚本片段。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明（7）：自定义 JSP 标签

shop.tld 注册 MaskTag，页面通过 <shop:mask> 输出脱敏姓名。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明（8）：SM3 工具类

Sm3Util 封装 BouncyCastle 国密摘要计算和盐值生成。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明（9）：SM4 工具类

Sm4Util 使用随机 IV 和 Base64 编码保存密文，避免同一明文产生完全相同密文。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明 (10) : RBAC 策略测试

RbacPolicyTest 验证审计管理员、运营管理员、系统管理员和普通客户的访问边界。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明 (11) : 审计日志写入

AuditService 负责写入日志，命令层只传递动作名称和简短详情。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明（12）：ECharts 统计页

admin/stats.jsp 引入 vendored echarts.min.js，既显示图表，也保留表格降级展示。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明 (13) : WAR 打包

maven-war-plugin 产出 target/bookstore.war , 适合课程提交和 Tomcat 部署。

该实现点的设计原则是把变化隔离在明确位置 , 并让代码路径足够短。课程答辩时可以从页面操作开始 , 沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具 , 避免超出课程栈 , 也减少部署和说明成本。

代码位置清晰。

依赖少 , 方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明（14）：嵌入式演示

Launcher 使用 Tomcat 10.1 嵌入式 API，把 src/main/webapp 作为 Web 根目录启动。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第七章 关键代码与实现说明 (15) : 测试策略

自动测试集中覆盖安全、服务和路由逻辑，页面流程通过真实 MySQL 和浏览器烟测验证。

该实现点的设计原则是把变化隔离在明确位置，并让代码路径足够短。课程答辩时可以从页面操作开始，沿 Servlet、Command、Service、DAO 到 SQL 逐层说明。

该部分没有引入 Spring Boot 或前端构建工具，避免超出课程栈，也减少部署和说明成本。

代码位置清晰。

依赖少，方便现场演示。

和课程要求技术点直接对应。

第八章 测试与验证（一）：自动化构建

本次最终验证运行 `mvn package`，测试统计为 61 个测试、0 失败、0 错误，并成功生成 `target/bookstore.war`。

烟测基于真实本地 MySQL 和嵌入式 Tomcat，不只验证静态页面。每个关键路径都通过浏览器或数据库查询确认结果。

测试数据完成后导出数据库备份，便于教师在本地恢复同样的演示状态。

构建：`mvn package`。

运行：`mvn -q compile exec:java -Dexec.mainClass=com.bookstore.Launcher`。

数据库：`mysqldump --single-transaction --set-gtid-purged=OFF`。

第八章 测试与验证（二）：数据库初始化

使用 `schema.sql` 与 `seed.sql` 重置 MySQL 数据库，种子数据包含四类角色、图书目录和分类数据。

测试基于真实本地 MySQL 和嵌入式 Tomcat，不只验证静态页面。每个关键路径都通过浏览器或数据库查询确认结果。

测试数据完成后导出数据库备份，便于教师在本地恢复同样的演示状态。

构建：`mvn package`。

运行：`mvn -q compile exec:java -Dexec.mainClass=com.bookstore.Launcher`。

数据库：`mysqldump --single-transaction --set-gtid-purged=OFF`。

第八章 测试与验证（三）：用户端闭环

浏览图书、加入购物车、更新数量、移除商品、结算生成订单、管理员发货后客户确认收货。

测试基于真实本地 MySQL 和嵌入式 Tomcat，不只验证静态页面。每个关键路径都通过浏览器或数据库查询确认结果。

测试数据完成后导出数据库备份，便于教师在本地恢复同样的演示状态。

构建：mvn package。

运行：mvn -q compile exec:java -Dexec.mainClass=com.bookstore.Launcher。

数据库：mysqldump --single-transaction --set-gtid-purged=OFF。

第八章 测试与验证（四）：管理端闭环

运营管理员完成图书新增、分类新增删除、订单发货、用户启停和销售统计查看。

烟测基于真实本地

MySQL

和嵌入式

Tomcat，不只验证静态页面。每个关键路径都通过浏览器或数据库查询确认结果。

测试数据完成后导出数据库备份，便于教师在本地恢复同样的演示状态。

构建：mvn package。

运行：mvn -q compile exec:java -Dexec.mainClass=com.bookstore.Launcher。

数据库：mysqldump --single-transaction --set-gtid-purged=OFF。

第八章 测试与验证（五）：安全闭环

审计管理员可以查看审计日志，但访问销售统计会被拒绝。用户管理页面展示姓名脱敏。

403

烟测基于真实本地 MySQL Tomcat，不只验证静态页面。每个关键路径都通过浏览器或数据库查询确认结果。

和嵌入式

测试数据完成后导出数据库备份，便于教师在本地恢复同样的演示状态。

构建：mvn package。

运行：mvn -q compile exec:java -Dexec.mainClass=com.bookstore.Launcher。

数据库：mysqldump --single-transaction --set-gtid-purged=OFF。

图 8-1 用户端图书列表



图 8-1 用户端图书列表

该截图来自最终 DB-backed 烟测流程，作为报告中的运行证据。截图只展示必要业务信息，不包含演示口令。

图 8-2 购物车数量与金额展示

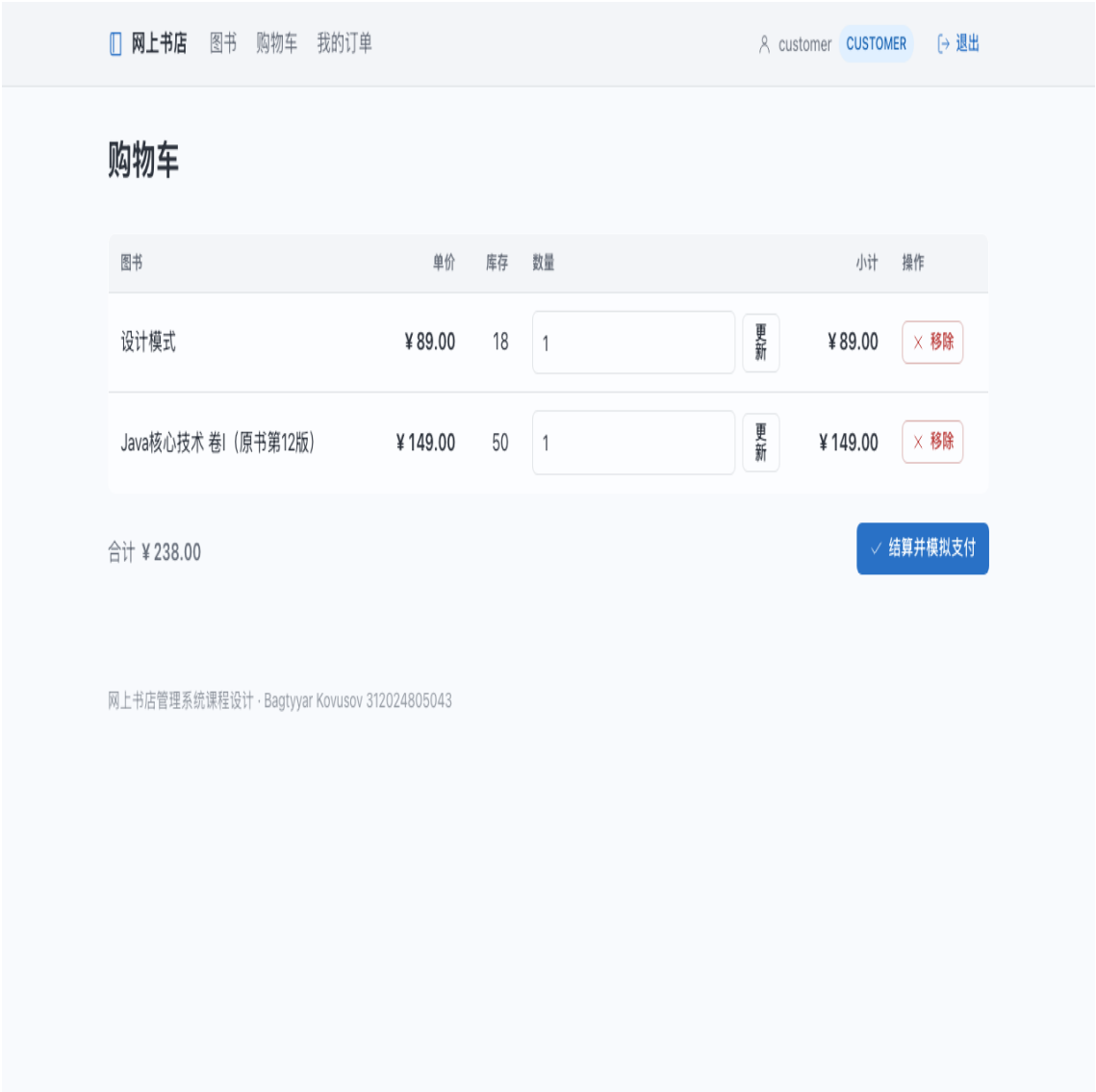


图 8-2 购物车数量与金额展示

该截图来自最终DB-backed
烟测流程，作为报告中的运行证据。截图只展示必要业务信息，不包含演示口令。

图 8-3 客户订单详情

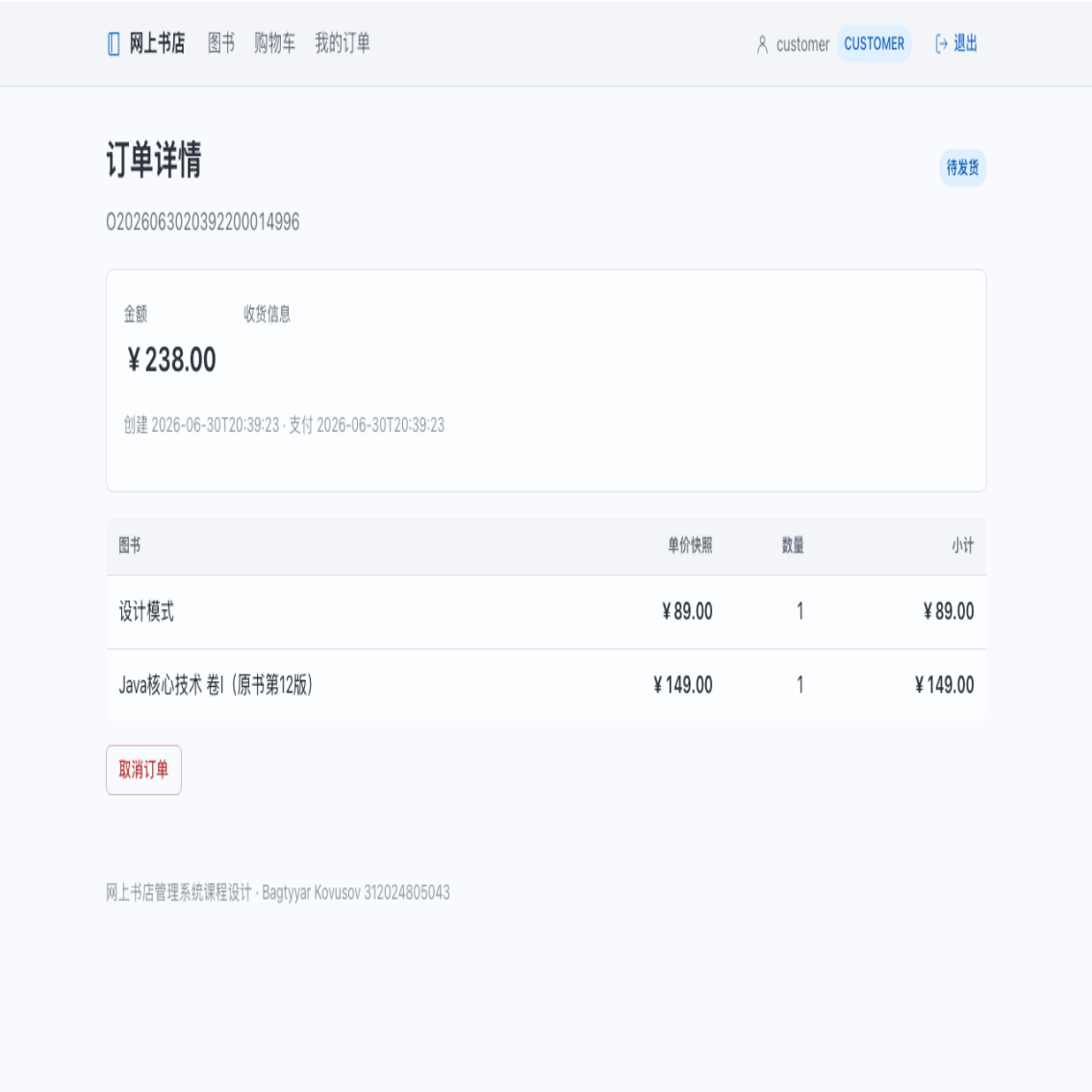


图 8-3 客户订单详情

该截图来自最终 DB-backed 烟测流程，作为报告中的运行证据。截图只展示必要业务信息，不包含演示口令。

图 8-4 管理后台首页

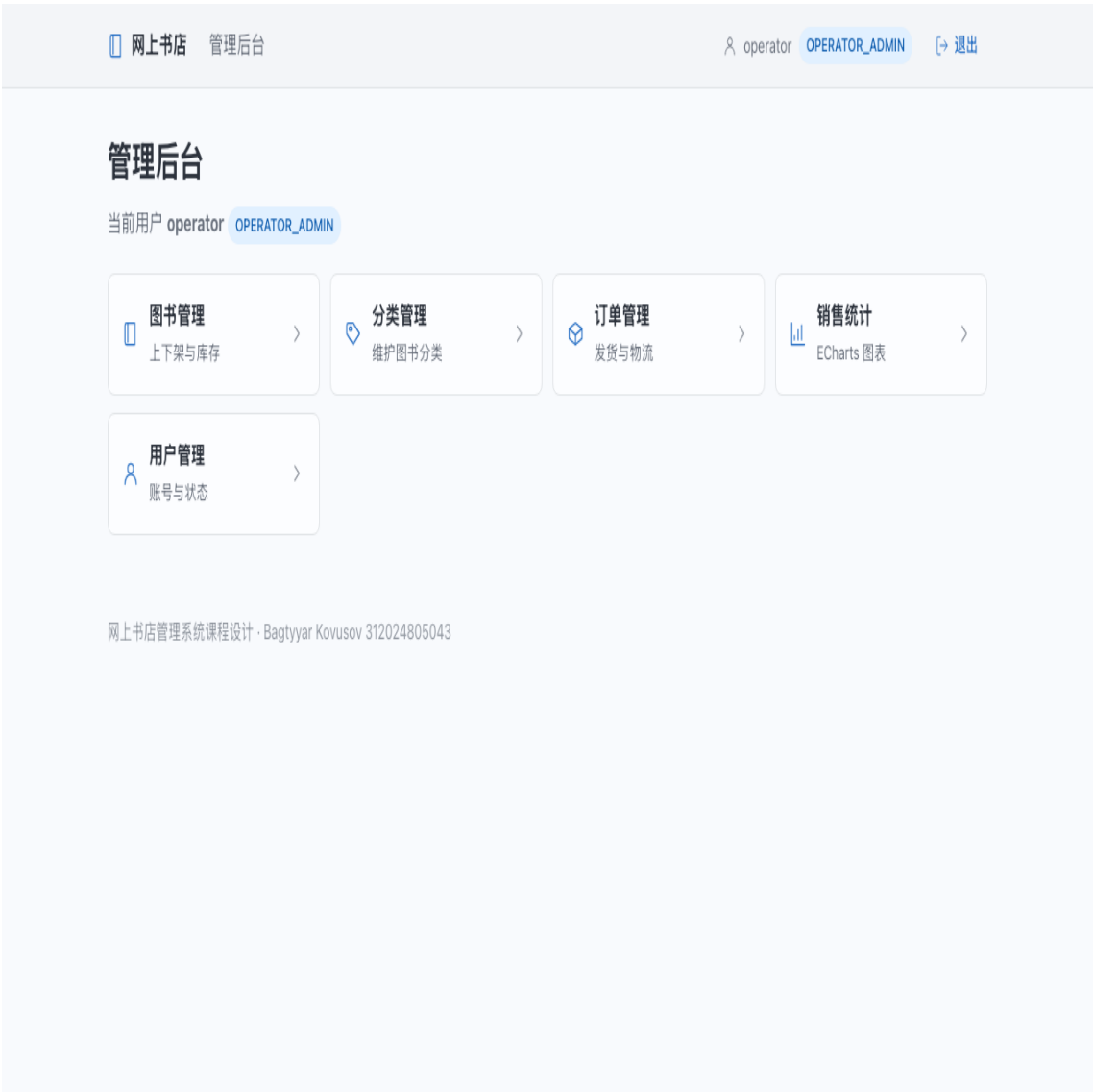


图 8-4 管理后台首页

该截图来自最终
DB-backed
烟测流程，作为报告中的运行证据。截图只展示必要业务信息，不包含演示口令。

图 8-5 图书管理列表

网上书店 管理后台

operator OPERATOR_ADMIN 退出

图书管理

新增图书

ID	书名	作者	ISBN	价格	库存	状态	操作
1	Java核心技术 卷I (原书第12版)	Cay S. Horstmann	9787111709473	¥ 149.00	49	上架	编辑下架
2	深入理解Java虚拟机 (第3版)	周志明	9787111641247	¥ 129.00	30	上架	编辑下架
3	算法导论 (原书第3版)	Thomas H. Cormen	9787111407010	¥ 128.00	20	上架	编辑下架
4	活着	余华	9787506365437	¥ 45.00	80	上架	编辑下架
5	三体 (全三册)	刘慈欣	9787229137939	¥ 168.00	60	上架	编辑下架
6	时间简史	史蒂芬·霍金	9787535732309	¥ 45.00	40	上架	编辑下架
7	新概念英语 (2)	亚历山大·何其莘	9787560022086	¥ 38.00	100	上架	编辑下架
8	考研数学复习全书	李永乐	9787109267701	¥ 89.00	25	上架	编辑下架

图 8-5 图书管理列表

该截图来自最终

DB-backed

烟测流程，作为报告中的运行证据。截图只展示必要业务信息，不包含演示口令。

图 8-6 订单发货结果

网上书店 管理后台

operator OPERATOR_ADMIN 退出

订单管理

ID	订单号	用户ID	金额	状态	快递单号	创建时间	操作
20	O2026063020392200014996	1	¥ 238.00	已完成	YT202606300099	2026-06-30T20:39:23	详情
11	O20260629091500000011001	8	¥ 128.00	待支付		2026-06-29T17:15	详情
6	O20260628121500000006001	9	¥ 45.00	已取消		2026-06-28T20:15	详情
19	O20260627180000000019001	1	¥ 99.00	待支付		2026-06-28T02:00	详情
10	O20260626100000000010001	7	¥ 77.00	已完成	YT202606260005	2026-06-26T18:00	详情
5	O20260625113000000005001	8	¥ 89.00	已完成	YT202606250002	2026-06-25T19:30	详情
15	O20260624093000000015001	6	¥ 45.00	已完成	YT202606240007	2026-06-24T17:30	详情
9	O20260623162000000009001	6	¥ 149.00	已发货	YT202606230004	2026-06-24T00:20	详情
8	O20260622110000000008001	5	¥ 77.00	待发货		2026-06-22T19:00	详情
16	O20260621070000000016001	7	¥ 128.00	待支付		2026-06-21T15:00	详情
4	O20260620104500000004001	7	¥ 168.00	已发货	YT202606200001	2026-06-20T18:45	详情

图 8-6 订单发货结果

该截图来自最终

DB-backed

烟测流程，作为报告中的运行证据。截图只展示必要业务信息，不包含演示口令。

图 8-7 用户管理姓名脱敏

网上书店 管理后台

operator OPERATOR_ADMIN 退出

用户管理

运营管理员只能管理普通客户；系统管理员可管理非系统管理员账号。

ID	用户名	姓名	角色	状态	失败次数	锁定至	操作
1	customer	张*	CUSTOMER	ACTIVE	0	禁用	TempPass@123 重置密码
2	operator	运*李	OPERATOR_ADMIN	ACTIVE	0	禁用	TempPass@123 重置密码
3	sysadmin	系*员	SYSTEM_ADMIN	ACTIVE	0	禁用	TempPass@123 重置密码
4	auditor	审*员	AUDIT_ADMIN	ACTIVE	0	禁用	TempPass@123 重置密码
5	wangfang	王*	CUSTOMER	ACTIVE	0	禁用	TempPass@123 重置密码
6	lihua	李*	CUSTOMER	ACTIVE	0	禁用	TempPass@123 重置密码
7	zhaolei	赵*	CUSTOMER	ACTIVE	0	禁用	TempPass@123 重置密码
8	sunli	孙*	CUSTOMER	ACTIVE	0	禁用	TempPass@123 重置密码

图 8-7 用户管理姓名脱敏

该截图来自最终

DB-backed

烟测流程，作为报告中的运行证据。截图只展示必要业务信息，不包含演示口令。

图 8-8 ECharts 销售统计



图 8-8 ECharts 销售统计

该截图来自最终

DB-backed

烟测流程，作为报告中的运行证据。截图只展示必要业务信息，不包含演示口令。

图 8-9 审计日志查询

网上书店 管理后台

auditor AUDIT_ADMIN 退出

审计日志

按用户名、动作、日期和关键字查看最近 200 条审计记录。

用户名

动作, 如 LOGIN_SUCCESS

关键字

yyyy/mm/dd

yyyy/mm/dd

筛选

清空

ID	时间	用户ID	用户名	动作	详情	IP
18	2026-06-30T20:39:46	4	auditor	LOGIN_SUCCESS	username=auditor	0:0:0:0:0:0:1
17	2026-06-30T20:39:44	2	operator	LOGOUT	path=/app/logout	0:0:0:0:0:0:1
16	2026-06-30T20:39:41	2	operator	ADMIN_VIEW	method=GET,path=/admin/users	0:0:0:0:0:0:1
15	2026-06-30T20:39:41	2	operator	ADMIN_VIEW	method=GET,path=/admin/orders	0:0:0:0:0:0:1
14	2026-06-30T20:39:40	2	operator	LOGIN_SUCCESS	username=operator	0:0:0:0:0:0:1
13	2026-06-30T20:39:38	1	customer	LOGOUT	path=/app/logout	0:0:0:0:0:0:1
12	2026-06-30T20:39:37	1	customer	ORDER_CONFIRM	orderId=20	0:0:0:0:0:0:1
11	2026-06-30T20:39:36	1	customer	LOGIN_SUCCESS	username=customer	0:0:0:0:0:0:1

图 8-9 审计日志查询

该截图来自最终

DB-backed

烟测流程，作为报告中的运行证据。截图只展示必要业务信息，不包含演示口令。

图 8-10 审计员越权访问被拒绝



图 8-10 审计员越权访问被拒绝

该截图来自最终
DB-backed
烟测流程，作为报告中的运行证据。截图只展示必要业务信息，不包含演示口令。

第九章 部署与交付

交付目录包含源代码、target/bookstore.war、schema.sql、seed.sql、数据库备份、截图、技术报告、系统使用说明书和课程设计报告。

恢复演示环境时先启动 MySQL，执行 schema.sql 与 seed.sql 或直接恢复 bookstore-backup-2026-06-30.sql，再启动嵌入式 Tomcat。

如使用外部 Tomcat 10 部署，可把 target/bookstore.war 复制到 webapps 目录，数据库配置仍读取 WEB-INF/classes 中的 db.properties。

源码目录：src/main/java 与 src/main/webapp。

SQL 脚本：src/main/resources/schema.sql、seed.sql。

备份文件：deliverables/db/bookstore-backup-2026-06-30.sql。

附录 A：答辩技术要点

答辩时建议先演示普通用户购书闭环，再演示管理员发货和销售统计，最后演示审计员只能查看日志不能访问业务管理页。

代码说明按技术点组织：Servlet 路由、JSP/JSTL 页面、JavaBean 模型、JDBC DAO、MVC 分层、自定义 JSP 标签、国密 SM3/SM4、安全审计。

对于未实现的扩展项，应明确说明它们是可选范围，例如评价、多地址、退款和复杂推荐。本系统优先完成评分核心技术点。

最能体现课程要求的文件：DispatcherServlet、MaskTag、UserService、OrderService、StatsService。

最能体现数据库设计的表：orders、order_item、audit_log、user。

附录 B：总结

本系统完成了课程设计中网上书店的核心业务闭环，并围绕安全要求补充国密摘要、国密加密、脱敏、访问控制和安全审计。

项目结构保持朴素，适合在课程答辩中解释每一层职责。最终构建、浏览器烟测和数据库备份均已完成。

后续如果继续扩展，可以优先补齐评价模块、多收货地址、低库存预警和更完整的报表维度。

收获一：分层设计降低了功能扩展成本。

收获二：安全控制需要从登录、数据、页面和日志同时考虑。

收获三：最终交付必须包含可恢复的数据和可复现的验证步骤。

附录：路由清单说明

路由清单说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：用户表字段说明

用户表字段说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：图书表字段说明

图书表字段说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：订单状态流转说明

订单状态流转说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：购物车唯一约束说明

购物车唯一约束说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：审计动作枚举说明

审计动作枚举说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：销售统计 SQL 说明

销售统计 SQL 说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：密码策略测试说明

密码策略测试说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：登录锁定测试说明

登录锁定测试说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：SM4 加解密测试说明

SM4 加解密测试说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：RBAC 测试说明

RBAC 测试说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：遮罩标签测试说明

遮罩标签测试说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：服务层测试说明

服务层测试说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：命令层测试说明

命令层测试说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：页面烟测矩阵

页面烟测矩阵用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：部署环境说明

部署环境说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：备份恢复说明

备份恢复说明用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：常见演示问题处理

常见演示问题处理用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：可扩展功能规划

可扩展功能规划用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。

附录：课程要求对应表

课程要求对应表用于辅助答辩和复查。该部分把实现细节转化为可说明的检查点，便于教师根据课程要求逐项核对。

项目没有依赖复杂框架，所有检查点都能在源码目录中找到直接对应文件。对于页面功能，可通过截图和数据库状态进行双重确认。

该附录页面也可作为现场演示时的提示材料，帮助按技术点而不是按代码文件顺序讲解。

检查源代码位置。

检查数据库状态。

检查页面或测试输出。